



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



B&R PPT30 Operating System

Vulnerability Report

Classification	TLP:CLEAR
Published	2026-06-16
Version	1.0
Author	Lost Boys Cyber
Report Type	Vulnerability Report

TLP:CLEAR | Lost Boys Cyber | B&R PPT30 Operating System - Vulnerability Report

Published: 2026-06-16 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirement
3. Source Review and Confidence
4. Key Findings
5. Threat Context
6. Detection and Hunting
7. Recommendations
8. References

B&R PPT30 Operating System OPC-UA Denial-of-Service Vulnerability

1. Executive Summary

B&R PPT30 Operating System versions before `1.8.0` are affected by `CVE-2025-11482`, a high-severity allocation-of-resources-without-limits-or-throttling vulnerability in the product's optional OPC-UA Server. CISA republished ABB/B&R advisory `SA25P006` as `ICSA-26-155-03` on 2026-06-04. Successful exploitation can make the OPC-UA server inaccessible to legitimate users, creating an availability-impacting denial-of-service condition against industrial control environments that depend on PPT30 telemetry, operator workflows, or upstream integration through OPC-UA.

The vulnerability does not require authentication, user interaction, or a privileged account. The public CVSS v3.1 vector is `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:U/RL:O/RC:C`, producing a base score of `7.5 HIGH`. The impact is limited to availability in the public advisory; no confidentiality or integrity compromise is described. That limitation still matters in operational technology because loss of an OPC-UA service can degrade visibility, historian ingestion, supervisory workflows, and operator decision support even when the underlying process controller remains otherwise intact.

B&R states that the OPC-UA server is not activated by default and that PPT30 products are intended to operate at Levels 1 and 2 of the ABB ICS Cyber Security Reference Architecture. Exposed risk is therefore concentrated in environments where the optional OPC-UA server has been enabled and reachable from untrusted or weakly segmented networks. Lost Boys Cyber assesses the highest-priority exposure cases as critical manufacturing, energy, transportation, water/wastewater, and commercial facilities networks where PPT30 assets bridge control networks with monitoring, engineering, or business-adjacent systems.

Immediate defender priorities are to identify deployed PPT30 Operating System versions, confirm whether the optional OPC-UA server is enabled, upgrade affected devices to PPT30 Operating System `1.8.0`, restrict OPC-UA access to trusted IP addresses through the South Firewall and/or Control Network Firewall, and hunt for unusual connection volume, session churn, or repeated OPC-UA traffic to PPT30 endpoints. Public sources state that B&R had not received exploitation reports at original publication time; defenders should nevertheless treat any Internet-reachable or broadly reachable OPC-UA service as a preventable exposure requiring prompt containment.

2. Intelligence Requirement

This report answers the following intelligence requirement: what does `CVE-2025-11482` mean for defenders operating B&R PPT30 assets, which exposure patterns require immediate mitigation, and what detection, hunting, and operational controls should be prioritized to prevent or identify OPC-UA service denial-of-service activity?

Question	Assessment
What is vulnerable?	B&R PPT30 Operating System versions before `1.8.0` when the optional OPC-UA Server is enabled.
What is the flaw class?	`CWE-770: Allocation of Resources Without Limits or Throttling`.
What can an attacker do?	Permanently prevent legitimate users from interacting with the OPC-UA service, according to CISA/B&R advisory language.
What access is required?	Unauthenticated network access to the affected OPC-UA server; no user interaction is required.
What is the operational impact?	Availability loss for OPC-UA connectivity, potentially affecting monitoring, integration, historian, engineering, or supervisory workflows that depend on the service.
What is the priority action?	Upgrade to PPT30 Operating System `1.8.0`, disable OPC-UA where not required, and restrict OPC-UA access to trusted IP ranges through firewall segmentation.

Is exploitation confirmed?	No public exploitation was reported in the reviewed CISA/B&R advisory at original publication time; CVSS temporal exploit-code maturity is `Unproven`.
----------------------------	--

Assumptions used in this assessment: the report is written from public advisory material and generic ICS/OPC-UA defensive practice. No customer-specific network diagrams, asset inventories, firewall policies, packet captures, or device logs were provided. Recommendations therefore prioritize defensible controls that can be validated locally without requiring proof-of-concept exploit details.

3. Source Review and Confidence

Source	Contribution	Confidence
CISA `ICSA-26-155-03`, B&R PPT30 Operating System	Primary public advisory page with affected product, CVE, CVSS, sectors, remediation, mitigations, and CISA ICS recommended practices.	High
CISA CSAF JSON for `ICSA-26-155-03`	Machine-readable authoritative fields for tracking dates, references, CVSS vector, CWE, remediation categories, and revision history.	High
ABB/B&R CSAF advisory `SA25P006`	Vendor-origin source referenced by CISA; identifies product context, fixed version, OPC-UA default state, firewall guidance, and support path.	High
B&R PDF advisory `SA25P006`	Vendor PDF form of the advisory, useful for customer-facing citation and change-control packets.	High
NVD / CVE Program references for `CVE-2025-11482`	CVE enrichment and cross-reference validation for vulnerability identifiers, weakness mapping, and severity metadata.	Medium-High
CISA ICS recommended practices and Defense-in-Depth guidance	Defensive context for network exposure reduction, segmentation, remote access, and ICS monitoring.	High

Confidence is high that the vulnerability exists, affects the stated PPT30 Operating System version range, and is corrected in `1.8.0`. Confidence is also high that network segmentation materially reduces practical exploitability because the vulnerable service is optional and network-reachable exploitation requires access to the affected OPC-UA endpoint.

Confidence is moderate regarding real-world exploitation likelihood. The public advisory states that the vulnerability was discovered through B&R's own security analysis, had not been publicly disclosed when the advisory was issued, and had not been reported as exploited at original publication time. No public proof-of-concept or campaign reporting was identified in the reviewed material. The lack of public exploitation does not remove operational risk, especially where OPC-UA endpoints are reachable from flat plant networks, poorly governed remote-access paths, or accidentally exposed enterprise segments.

4. Key Findings

Finding	Severity	Confidence	Defensive implication
---------	----------	------------	-----------------------

`CVE-2025-11482` enables unauthenticated network-based denial of service against the PPT30 OPC-UA Server.	High	High	Treat enabled OPC-UA services on affected PPT30 assets as urgent patch-and-segment candidates.
The vulnerable OPC-UA server is optional and not activated by default.	Medium	High	Asset owners must verify actual service state; version alone does not prove exposure if OPC-UA remains disabled.
The fixed version is PPT30 Operating System `1.8.0`.	High	High	Upgrade planning should target `1.8.0` or later and record installed versions for audit evidence.
Impact is availability-only in public scoring, with no confidentiality or integrity impact described.	High	High	Incident severity should be based on process dependency and loss-of-visibility consequences, not data theft assumptions.
Public exploitation was not reported at advisory publication time.	Medium	High	Do not claim active exploitation without local evidence, but monitor for opportunistic scanning or service-stress attempts.
CISA lists deployment across commercial facilities, critical manufacturing, energy, transportation, and water/wastewater sectors.	High	High	Prioritize exposed PPT30 assets in critical process, safety-adjacent, and high-availability environments.

4.1 Vulnerability metadata

Field	Value
Advisory	`ICSA-26-155-03` / ABB PSIRT `SA25P006`
CVE	`CVE-2025-11482`
Product	B&R Industrial Automation GmbH PPT30 Operating System
Affected versions	PPT30 Operating System before `1.8.0`
Fixed version	PPT30 Operating System `1.8.0`
Vulnerable component	Optional OPC-UA Server used in PPT30 Operating System
Weakness	`CWE-770: Allocation of Resources Without Limits or Throttling`
CVSS v3.1	`7.5 HIGH`
CVSS vector	`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/E:U/RL:O/RC:C`
Attack requirements	Network access, low complexity, no privileges, no user interaction
Impact	Availability high; confidentiality none; integrity none

Initial vendor release	2026-05-26
CISA republication	2026-06-04
Reported by	ABB PSIRT
Deployment regions	Worldwide per CISA advisory
CISA sectors	Commercial Facilities, Critical Manufacturing, Energy, Transportation Systems, Water and Wastewater

4.2 Vulnerability mechanics

The advisory describes an allocation-of-resources-without-limits-or-throttling condition in the OPC-UA Server. In practical terms, a vulnerable service fails to sufficiently bound or throttle resource consumption when processing attacker-supplied network activity. An unauthenticated attacker with network reachability to the service can send messages to an affected system node and force the OPC-UA server into a state where legitimate users can no longer interact with it.

The public material does not disclose packet structure, a proof of concept, implementation-level root cause, or recovery requirements. The wording "permanently prevent legitimate users from interacting with the service" should be treated conservatively: operators should validate whether affected devices require service restart, device reboot, firmware remediation, or failover action after suspected triggering. Defensive testing should occur only in an authorized lab or maintenance window because denial-of-service validation against production control networks can itself create operational disruption.

4.3 Exposure details

Exposure pattern	Why it matters	Priority
PPT30 asset running OS ` <code><1.8.0`</code> with OPC-UA enabled and reachable from broad plant networks	Matches the vulnerable condition and gives many internal nodes an unauthenticated path to trigger service exhaustion.	Critical
OPC-UA reachable from enterprise IT, vendor remote access, jump-host, VPN, or wireless segments	Converts a compromise of non-control infrastructure into an OT service-availability risk.	Critical
OPC-UA exposed to the Internet or externally routable addresses	Contradicts CISA/ABB recommended practice and increases exposure to scanning and opportunistic denial-of-service attempts.	Critical
OPC-UA limited to trusted engineering or supervisory hosts with firewall enforcement	Reduces attack surface but still requires upgrade if service is enabled.	High
OPC-UA disabled on affected PPT30 devices	Practical exploit path is reduced; verify configuration drift and planned operational use before deprioritizing patching.	Medium
PPT30 upgraded to ` <code>1.8.0`</code> or later with segmented OPC-UA access	Reduced residual risk; continue monitoring for abnormal OPC-UA availability events and failed connection storms.	Reduced

5. Threat Context

OPC-UA is commonly used in industrial environments for telemetry exchange, supervisory integration, historian feeds, and interoperability between automation assets and higher-level systems. Its business value also makes it a high-consequence availability target: an outage may not directly modify process state, but it can blind operators, disrupt data pipelines, interrupt asset-management workflows, and force manual fallback procedures. In constrained industrial networks, even availability-only vulnerabilities can create outsized operational risk when visibility, alarm paths, or integration services are brittle.

The likely attacker set is broader than sophisticated ICS-specific adversaries. Any actor that obtains network access to the relevant control segment could attempt service disruption if exploit details become public: ransomware affiliates seeking operational pressure, hacktivists targeting visible critical infrastructure brands, insider threats, compromised vendor-access accounts, malware on engineering workstations, or opportunistic scanners on poorly segmented networks. The public advisory does not support attribution to a named actor or campaign.

Scenario	Description	Defensive implication
Compromised IT host pivots toward OT	Malware or an intruder on an enterprise workstation reaches TCP/4840 on PPT30 assets through weak segmentation.	Enforce firewall rules that allow OPC-UA only from defined engineering/supervisory hosts.
Vendor remote-access pathway is abused	A stolen VPN credential or exposed remote support path provides access to the control network.	Review VPN posture, MFA, jump-host logging, and remote-access network ACLs.
Flat plant network permits internal DoS	Any device on the plant network can repeatedly connect to the PPT30 OPC-UA endpoint.	Segment by asset role and apply least-privilege east-west controls.
Internet exposure or accidental NAT	OPC-UA is reachable from public IP space or broad external scanning.	Remove public exposure immediately; confirm no direct Internet access for control services.
Maintenance testing triggers instability	Authorized scanning or poorly throttled discovery overloads the vulnerable service.	Tune scanners, whitelist maintenance windows, and coordinate asset-owner approval for active checks.

MITRE ATT&CK mapping should remain conservative because the public advisory describes vulnerability impact but not an observed intrusion chain. The most supportable mapping is exploitation of a public-facing or network service for impact when the service is reachable, plus endpoint denial of service. Additional techniques such as remote services, ingress tool transfer, or command-and-control require local evidence and should not be asserted from this advisory alone.

Technique	Name	Evidence / rationale
`T0814`	Denial of Service	The vulnerability can make the OPC-UA server inaccessible to legitimate users in an ICS environment.
`T1499`	Endpoint Denial of Service	Enterprise ATT&CK analog for service-level exhaustion of a network-exposed endpoint.
`T0866`	Exploitation of Remote Services	ICS mapping is supportable when an attacker uses network access to exploit the OPC-UA service.
`T0883`	Internet Accessible Device	Use only where asset exposure review confirms public reachability or externally

		routable access.
`T0886`	Remote Services	Relevant when exploitation is attempted through VPN, jump-host, or vendor remote-access pathways.

6. Detection and Hunting

Detection should focus on three defensible signals: confirmed exposure of affected PPT30 assets, abnormal OPC-UA traffic patterns, and operational symptoms of OPC-UA unavailability. Because public sources do not provide exploit payload bytes, avoid overfitting detection to speculative packet content. Prioritize asset inventory, firewall/Zeek/NetFlow telemetry, endpoint network logs where available, switch/firewall counters, historian/supervisory alarms, and device/service health monitoring.

Signal	Telemetry source	Analytic goal
TCP/4840 or site-specific OPC-UA port reachable on PPT30 assets	Firewall, Zeek, NetFlow, network discovery, asset inventory	Confirm whether the vulnerable optional service is exposed.
High connection count, rapid session churn, or repeated failed OPC-UA interactions from one source	Firewall, Zeek `conn.log`, IDS, OPC-UA server logs	Identify possible resource-exhaustion attempts or unsafe scanning.
OPC-UA service unavailable while device remains otherwise reachable	Monitoring, historian, HMI/SCADA alerts, device health checks	Distinguish service-layer DoS from full device/network outage.
Untrusted source networks reaching control-network OPC-UA endpoints	Firewall logs, VPN logs, NAC, segmentation telemetry	Detect policy violations and pivot paths from IT/vendor networks.
New or unexpected PPT30 OS versions below `1.8.0`	CMDB, firmware inventory, passive OT asset discovery	Find vulnerable assets introduced through spares, replacement devices, or incomplete patch coverage.

6.1 Example Suricata threshold rule

Tune `\$PPT30\_OPCTUA\_SERVERS`, `\$TRUSTED\_OPCTUA\_CLIENTS`, and threshold values to the local environment. This rule is intentionally behavioral; it identifies unusually high OPC-UA connection volume to PPT30 servers rather than a vulnerability-specific payload.

```

alert tcp !$TRUSTED_OPCTUA_CLIENTS any -> $PPT30_OPCTUA_SERVERS 4840 (
  msg:"LBC Possible OPC-UA connection flood to B&R PPT30 server";
  flow:to_server;
  flags:S;
  threshold:type both, track by_src, count 50, seconds 60;
  classtype:attempted-dos;
  reference:cve,2025-11482;
  metadata:attack_target OT, product B_R_PPT30, service OPC-UA;
  sid:42025011482;
  rev:1;
)

```

6.2 Microsoft Defender / firewall hunt for OPC-UA access

```

let PPT30Servers = dynamic(["10.10.30.10", "10.10.30.11"]); // replace with PPT30 asset IPs
let TrustedOpcUaClients = dynamic(["10.10.20.15", "10.10.20.16"]); // replace with approved
HMI/engineering/historian clients
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemotePort == 4840 or LocalPort == 4840
| where RemoteIP in (PPT30Servers) or LocalIP in (PPT30Servers)
| extend PPT30IP = iff(RemoteIP in (PPT30Servers), RemoteIP, LocalIP)
| extend PeerIP = iff(RemoteIP in (PPT30Servers), LocalIP, RemoteIP)

```



```
| summarize Connections=count(), FirstSeen=min(Timestamp), LastSeen=max(Timestamp),
Devices=dcount(DeviceName) by PPT30IP, PeerIP, InitiatingProcessFileName
| extend TrustedClient = PeerIP in (TrustedOpcUaClients)
| where TrustedClient == false or Connections > 100
| order by Connections desc, LastSeen desc
```

6.3 Splunk hunt for firewall or Zeek OPC-UA bursts

```
index=network (dest_port=4840 OR id.resp_p=4840)
| eval src=coalesce(src_ip, id.orig_h), dest=coalesce(dest_ip, id.resp_h), action=coalesce(action,
conn_state)
| lookup ppt30_assets ip as dest OUTPUT asset_name os_version opcua_enabled
| where isnotnull(asset_name)
| bin _time span=5m
| stats count as connection_count dc(src) as unique_sources values(action) as actions
values(os_version) as os_version values(opcua_enabled) as opcua_enabled by _time src dest asset_name
| where connection_count > 50 OR unique_sources > 10 OR opcua_enabled="true" AND
mvfind(os_version, "^1\.[0-7]")>=0
| sort - connection_count
```

6.4 Hunt hypotheses

Hypothesis	Hunt approach	Escalation threshold
An untrusted host is probing or stressing PPT30 OPC-UA endpoints.	Review TCP/4840 flows to PPT30 assets by source, frequency, and trust zone.	Any source outside approved engineering/HMI/historian ranges.
Vulnerable PPT30 assets remain unpatched with OPC-UA enabled.	Join firmware inventory with service discovery and firewall policy.	Any OS ` <code><1.8.0`</code> where OPC-UA is enabled or reachable.
Remote access paths can reach OPC-UA directly.	Correlate VPN/jump-host sessions with OPC-UA network flows.	Vendor/user VPN accounts initiating OPC-UA traffic without an approved maintenance ticket.
OPC-UA service outages coincide with connection bursts.	Overlay service-health events with Zeek/firewall connection counts.	Service-down events within ± 15 minutes of anomalous connection volume.
Scanning tools are destabilizing the service.	Review vulnerability scanner, asset discovery, and network management sources.	Scans against PPT30 assets outside approved test windows or with aggressive timing.

6.5 Operational triage checklist

- Confirm whether the impacted asset is a PPT30 device and record OS version, serial/asset ID, network zone, process owner, and criticality.
- Confirm whether OPC-UA is enabled; if not required, disable it and document the business owner approval.
- Review recent firewall, Zeek, switch, VPN, and historian/service-health logs for repeated TCP/4840 activity or service-down events.
- Identify all source IPs that reached the service and classify them as approved clients, management infrastructure, vendor remote access, scanning tools, or unknown.
- If suspicious activity is present, preserve logs before rotation, capture a timeline, notify the OT asset owner, and avoid active exploit reproduction in production.

7. Recommendations

Priority	Owner	Action	Target outcome
Critical	OT asset owner / controls engineering	Identify all PPT30 assets and confirm installed OS version and OPC-UA service state.	Complete exposure inventory for ` <code>CVE-2025-11482`</code> .

Critical	OT asset owner / vendor support	Upgrade affected devices to PPT30 Operating System `1.8.0` or later, prioritizing enabled OPC-UA services.	Remove the vulnerable code path.
Critical	Network engineering	Restrict OPC-UA access to trusted IP addresses using the South Firewall and/or Control Network Firewall as recommended by B&R.	Prevent unauthenticated access from untrusted networks.
High	OT security / SOC	Deploy behavioral monitoring for OPC-UA connection bursts, untrusted-source access, and service-unavailability events.	Detect exploitation attempts and unsafe scanning.
High	Remote access owner	Validate VPN, jump-host, vendor access, and firewall rules to ensure remote users cannot directly reach PPT30 OPC-UA except through approved paths.	Reduce pivot risk from IT or vendor-access compromise.
High	Vulnerability management	Track `CVE-2025-11482` as an OT availability risk even where CVSS is not confidentiality/integrity impacting.	Ensure change boards prioritize process-critical services appropriately.
Medium	Operations / engineering	Disable OPC-UA where it is not required, and document any business justification for keeping it enabled.	Reduce optional attack surface.
Medium	Incident response	Prepare a service-outage triage runbook for PPT30 OPC-UA unavailability, including log sources, contact lists, and recovery steps.	Shorten outage response time and preserve evidence.

Implementation guidance should follow normal OT change-control discipline. Do not run active denial-of-service tests against production PPT30 devices. Validate patches in a lab or maintenance window, confirm fallback procedures before firmware work, and coordinate with process owners where OPC-UA loss could affect visibility, quality, or safety-adjacent workflows.

For environments unable to upgrade immediately, the defensible interim control is strict network access reduction: disable OPC-UA if not required; otherwise allow only known supervisory, historian, HMI, or engineering hosts to reach the service. Broad network reachability should be treated as a compensating-control failure, not as an acceptable long-term state.

8. References

- [1] CISA, `ICSA-26-155-03: B&R PPT30 Operating System`, 2026-06-04, <https://www.cisa.gov/news-events/ics-advisories/icsa-26-155-03>
- [2] CISA CSAF JSON, `icsa-26-155-03.json`, https://raw.githubusercontent.com/cisagov/CSAF/develop/csaf_files/OT/white/2026/icsa-26-155-03.json
- [3] ABB/B&R CSAF advisory `SA25P006`, <https://psirt.abb.com/csaf/2026/sa25p006.json>
- [4] ABB/B&R PDF advisory `SA25P006`, <https://br-cws-assets.de-fra-1.linodeobjects.com/SA25P006-0eec719c.pdf>
- [5] CVE Program, `CVE-2025-11482`, <https://www.cve.org/CVERecord?id=CVE-2025-11482>

- [6] NVD, `CVE-2025-11482`, <https://nvd.nist.gov/vuln/detail/CVE-2025-11482>
- [7] MITRE CWE, `CWE-770: Allocation of Resources Without Limits or Throttling`, <https://cwe.mitre.org/data/definitions/770.html>
- [8] CISA, ICS Recommended Practices, <https://www.cisa.gov/resources-tools/resources/ics-recommended-practices>
- [9] CISA, `Improving Industrial Control Systems Cybersecurity with Defense-in-Depth Strategies`, https://www.cisa.gov/sites/default/files/recommended_practices/NCCIC_ICS-CERT_Defense_in_Depth_2016_S508C.pdf